中国电子杯第三届高校 ICT 产教融合创新大赛

AegisAI

智能体驱动的 AI 安全知识情报系统

赛题九 · 校内初赛技术讲解

AegisAI 技术讲解

01 **背景与架构**

现状四大断裂（散/幻/浮/慢）、四维需求映射与六层解耦架构

02 **核心机制设计**

智能体分工流水线、受约束规划、Claim-Evidence 血缘核验与确定性 Gate

03 **工程纵深实现**

DAG Runtime、Tool Gateway 权限三分、Model Gateway、幂等与双库安全隔离

04 **功能实证与评测**

原生 JS 工作台实机展示、C08/C09 端到端调查、1426 项回归与 49 题评测

05 **创新与比较**

三大核心创新总结、四条基线机制对比与初赛评分指标达成

01 背景与架构

现状痛点 · 需求映射 · 多源监测 · 六层架构

需求与输入	直击“多源分散、大模型幻觉、脱离资产、人工滞后”四大断裂。
监测与数据	找全、验真、落地、及时四条需求逐一映射至已实现模块。
系统职责	六层逻辑架构解耦，PostgreSQL 共享知识底座贯通全链路。

项目定位：将大模型非确定性输出转化为可核验、可追溯的安全结论

输入

证 · 证据驱动
Claim 与 Evidence 分离存储

字段严格区分「来源断言 / 候选线索 / 核验确认」三档，外部公告原文先留痕后使用。

→

处理

协 · 多智能体协同
受约束 Planner + 三专业 Agent

输出

验 · 确定性验收
Integration Gate
六维规则
模型无权自封结论
可信

自主决策严格限定在合法调查计划与工具选择范围内 —— 事实核验与风险规则绝不交由模型自由裁决。

现状痛点：传统工具只给链接、普通大模型易生幻觉（四处断裂）

散 • 多源信息分散

漏洞库、厂商公告、博客、论文各自为政；同一漏洞的别名、多分支范围散落各处，人工拼接成本高。

幻 • 输出无法核验

直接把问题交给单次大模型，答案无法区分「已确认事实 / 同源转载 / 模型推测」，安全场景无法采信。

浮 • 脱离资产上下文

「漏洞存在」不等于「我受影响」；缺少调查时刻的组件包生态与维护分支观察，结论落不到具体资产。

慢 • 人工核查滞后

从公告发布到应急处置依赖人工逐篇读文、比对版本与复核出处，情报时效在流程中层层流失。

四维需求映射：从信息收集到可核查的调查结果

找全

多源采集与原文留存

漏洞库、厂商公告、技术博客与论文进入统一知识流程；RawDocument 保留原文，Checkpoint 支持续采与批次追踪。

验真

声明与证据分离核验

区分来源断言、候选线索与核验确认，逐条检查直接支持、反证和来源血缘。

落地

绑定登记资产与版本

以授权库存的版本观察作为调查上下文，比较维护分支，再形成风险与修复建议。

及时

减少人工交接并记录异常

采集、富化、调查与封存以服务接口衔接；失败和部分执行留痕，时效仍需独立测试。

多源异构情报采集与 RawDocument 原文留痕（解决「找全」问题）

来源	采集与保存	已有记录
NVD / OSV	CVE / NVD / OSV / GitHub Advisory / KEV 结构化同步与 Checkpoint 续采	SHA-256 原文留痕
RSS 技术博客	Trail of Bits 等安全研究 RSS 经安全 XML 解析入库，构建 384 维本地向量索引	384 维本地向量索引
arXiv	arXiv AI 安全论文元数据与摘要入库，支持关键词精确索引与语义混合检索	语义 + 关键词混合检索

> 所有外部资料先保存 RawDocument 原始快照与 SourceObservation 采集回执，失败与 PARTIAL 批次显式留痕。

六层逻辑架构解耦：共享知识库贯通「采集—富化—调查—问答」全链路

6	**用户应用**	原生 JS 工作台 · TypeScript Client（情报总览 / 漏洞中心 / 资产风险 / 证据复核 / 智能调查）
5	**知识问答**	Orchestrator 总控 · AnswerEnvelope 封存交付 · 42 个 HTTP 契约操作
4	**智能体分析**	**受约束 Planner（task-plan-v1）• 调查 / 核验 / 风险三专业 Agent • 确定性 Gate**
3	**情报富化**	Claim–Evidence 分离建模 · vendor / EPSS / KEV / PoC / Patch / version 六维富化
2	**情报监测**	多源增量采集 · Normalizer 标准化 · RawDocument 快照与 SourceObservation 留痕
1	**数据来源**	公开权威安全数据源：CVE · NVD · OSV · GitHub Advisory · CISA KEV · 技术博客 · arXiv 论文

共享知识底座（PostgreSQL）：原文 / 声明 / 证据 / 产物 / 审计全量入库，按调查 ID 可完整回放。

02 核心机制设计

多智能体分工 · 受约束规划 · 证据链核验 · 资产分支闭环 · 确定性 Gate

规划校验	Planner 只提计划不拿执行权限，服务端强制校验 Schema、白名单与必需任务。
来源与范围	Claim–Evidence 三档分离存储，origin() 归并同源转载，精准匹配维护分支。
结果封存	Integration Gate 六维确定性规则统一验收，AnswerEnvelope 结构化封存交付。

智能体流水线：受约束 Planner 规划，三专业 Agent 分工，Gate 独立验收

用户请求 → **Planner** → **Runtime** → **Gate / 答案**

原目标与必需任务

模型生成候选计划

校验后按依赖调度

验收与结果封存

01 调查 Agent

经 8 个注册工具读取漏洞、证据、资产与语义结果；产出 InvestigationArtifact，未解决项留痕。

→ 02 核验 Agent

在固定快照上按来源血缘核验声明与证据；输出 CONFIRMED / CONFLICT / INSUFFICIENT_EVIDENCE。

→ 03 风险 Agent

包生态匹配、多维护分支范围比较、CVSS 向量与 KEV/PoC/补丁信号归因；输出风险与优先级。

核心机制一：受约束任务规划与服务端必需任务不变量（task-plan-v1）

用户目标 → **模型候选计划** → **受控执行**

服务端提取 RequiredTask 不变量

生成候选 DAG 与 acceptance_criteria

三重校验通过后按 DAG 调度执行

服务端独立约束

JSON Schema + Pydantic 严格校验

仅允许调用 8 个服务端注册工具

DAG 环路检查 + 深度/并发/时限约束

complete_required_tasks 补齐必需节点

计划修正自愈机制

模型只提计划不拿权限：查询超范围（QUERY_SCOPE_MISMATCH）或缺失字段（如 C09）直接拦截，在两次预算内经 schema_feedback 自动修正。

核心机制二：声明与证据三档分离存储及跨源血缘消歧（Lineage）

Claim–Evidence 分离建模与同源归并

GitHub 原公告 ⟶ **OSV 转录记录**

外部公告原文 RawDocument 留痕

字段区分「来源断言 / 候选线索 / 核验确认」三档

跨源同出处归并（origin 算法）

穿透 NVD / OSV / GHSA 转载链，不按网址数量盲目累加权重

核验角色在固定快照上核对作用域、原文定位与反证，CONFIRMED 方可作为决策依据

22 次同源重复确认实例在评测中被精准识别并拦截（涉及 7 题、4 类核心声明）。有效防止将“同一份公告被多处转载”误判为“多源独立交叉印证”。

核心机制三：授权资产快照绑定与多维护分支版本区间比对

多维护分支独立区间比对（以 C08 为例）

0.x	<0.3.81	修复：0.3.81
1.x	**≥1.0.0 且 <1.2.5**	**修复：1.2.5**

固定资产观察（VersionObservation）：
PyPI / langchain-core @ 1.2.0

命中 1.x 分支 [1.0.0, 1.2.5) → 判定 AFFECTED（HIGH / P2），绑定证据推荐升级至 1.2.5；缺失版本或来源冲突时绝不盲猜。

核心机制四：Integration Gate 六维确定性门禁统一验收

Completion

必需任务与三角色产物齐全（阻断取消、失败、依赖阻塞）

Integrity

身份、来源与引用链闭合（阻断跨调查产物混用）

Evidence

决策事实具备直接可信支持（识别 SHARED_SOURCE_LINEAGE）

Consistency

各角色状态与结论一致（阻断将 UNKNOWN 改写为安全）

Objective

回答原问题的必要部分（身份、资产、版本、修复、风险、优先级）

Freshness

来源发布时间、核验快照与资产观察满足时效要求

> 状态优先级：FAILED > HUMAN_REVIEW_REQUIRED > REPLAN_REQUIRED > PASS_WITH_WARNINGS > PASS（规则由服务端固定注册，模型无权关闭或裁决）。

核心机制五：AnswerEnvelope 结构化信封封存与五态交付契约

AnswerEnvelope 保存的内容

结论	verified_claims（已核验事实）与 disputed_claims（争议声明）严格分列
证据	citations 绑定具体 Evidence、RawDocument SHA-256 与原文 JSON 指针
执行记录	封存调查时刻 VersionObservation 与三角色 Artifact，同一答案重复读取一致

C08 / C09 的实际状态

Gate

PASS_WITH_WARNINGS

Answer

COMPLETE_WITH_WARNINGS

03 工程纵深实现

DAG Runtime · 权限与进程隔离 · 六维富化 · Model Gateway · 幂等与安全工程

受控执行 自研 DAG Runtime 验证依赖与环路，Tool Gateway 严格三分读/写/外网权限。

富化与模型 六类富化器按拓扑依赖执行并支持异常回滚；Model Gateway 显式隔离 Mock 与真实调用。

调查 API Idempotency-Key 幂等防重、拥有者绑定校验、Gitleaks 密钥扫描与双库隔离回归。

自研 DAG Runtime 依赖调度与 Tool Gateway 权限三分隔离

01

任务图

规划产物 DAG 拓扑解析

02

调度前检查

环路检测与配额上限保护

03

Tool Gateway

读取 / 写入 / 外网权限三分把关

04

持久化

TaskTrace 与 ToolReceipt 全量持久化

任务终态 SUCCESS / FAILED / WAITING_REVIEW / BLOCKED

子进程生命周期由执行层统一管控，单点异常不向主链扩散；上游必需节点失败时严格阻断下游，错误信息脱敏留痕。

执行隔离：工具权限、进程生命周期与失败状态分别管理

Tool Gateway 权限三分

读取

按角色授权读取漏洞、声明、证据与资产观察。

写入

领域产物和状态写入受角色及契约限制。

外部网络

网络访问单独准入，失败与部分执行明确记录。

执行生命周期

受控启动

执行层统一管理子进程与调用边界。

取消与超时

保存取消、超时及未完成状态。

失败与部分执行

Artifact、ToolReceipt 和原始异常分开留痕。

取消和超时为受控协作行为，不承诺任意子进程都能立即中止。异常信息经统一接口脱敏。

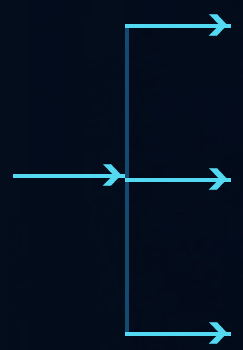
六维情报富化流水线：拓扑依赖调度、冲突检测与事务回滚

任务依赖

vendor

维护方说明与来源观察

epss / kev



poc

patch

version

补充公开风险信号；poc、patch、version 三类候选任务依赖 vendor。

执行与保存

输出结构化领域对象、Claim/Evidence 候选 ID 与任务级耗时回执

冲突与核验

区分 PoC 候选发现与利用实证、区分 FIXED_VERSION 与 PATCH_APPLIED

失败与回滚

领域事务异常时精准回滚脏产物，完整保留已采集 RawDocument 与 FAILED 记录

Model Gateway 统一模型接入：供应商协议解耦与真实性隔离

调用方

受约束规划
已登记业务能力

请求

允许的消息、参数
与正式 Schema

响应

解析 JSON，执行类型
与 Schema 检查

Model Gateway

兼容 HTTP
本地 Embedding
Mock

记录

Provider、模型、耗时
trace、usage、is_mock

幂等键控制、访问隔离与内建安全工程（密钥扫描 + 双库隔离）

Idempotency-Key

同一个请求键

绑定拥有者与固定输入哈希

首次请求

创建异步调查（HTTP 202），状态、轨迹与产物独立留痕

相同合法固定输入

直接复用已封存历史结果，库存后续变化不改写历史答案

相同键、不同内容

立即返回冲突拒绝，防止复用旧键篡改或污染已有调查状态

安全工程内建：Gitleaks v8.30.1 全历史密钥扫描 0 未处理告警；两个独立空 PostgreSQL loopback 测试库严格隔离。

安全工程：密钥治理、双库隔离与仓库卫生

密钥治理

阶段扫描记录

Gitleaks v8.30.1 扫描 Git 历史，候选告警经确认后按精确指纹处理，复扫记录为 0 个未处理告警。

双库隔离

回归入口约束

两个独立空 PostgreSQL 测试库限制为 loopback 与专用库；真实库、外网库及不合规环境拒绝执行。

仓库卫生

避免凭据与运行产物入库

CI 检查 Git 跟踪文件，拒绝 .env、私钥、数据库、日志、虚拟环境与 node_modules 等运行产物。

失败审计

成功与异常均保留记录

FAILED、PARTIAL、取消和超时分别留痕；原始扫描与运行日志留在受控本地目录。

安全机制与阶段记录用于说明工程实现；不能替代连续运行可靠性及真实业务质量验收。

04 功能实证与评测

原生 JS 工作台 · 端到端调查 · 工程回归 · 独立展示基准口径

前端工作台

8 项调查 HTTP 操作与 42 项契约记录；保留提交调查、执行轨迹、证据与风险界面。

真实调查案例

C08 展示多维护分支比较，C09 展示原预算内字段修正；历史 vLLM 记录单列。

工程与质量分开

历史工程回归、专项测试与 AegisBench 分别呈现，测试通过数不替代问答质量。

前端工作台与后端接口契约：8 项调查操作与 42 个契约全量对齐

八项调查操作

POST /api/investigations	接受合法请求，返回 202
GET …/{id}/status、trace、artifacts	分别读取状态、轨迹与产物
GET …/{id}/integration、answer	分别读取 Gate 与封存答案
POST …/{id}/cancel	取消调查
GET /api/investigations/history	查询历史

原生 JavaScript ESM + History Router + Node 同源代理，TypeScript Client 与后端 42 个 OpenAPI 契约操作 100% 校验对齐。

新版问答工作台：调查入口与页面展示指标

真实 API 工作台（读取既有 C09 调查）

问答性能面板（网站当前展示口径）

真实端到端 HTTP 调查实证：C08 多分支匹配与 C09 计划自愈恢复

C08 / langchain-core 1.2.0 **52.50 s**

命中 1.x 分支 → 建议 1.2.5 → HIGH / P2

精准排除 <0.3.81 旧分支，锁定 1.x 分支修复版本 1.2.5，自动标注 SHARED_SOURCE_LINEAGE 同源提醒。

C09 / vLLM 0.29.0 **46.50 s**

补齐验收字段 → 按结构范围判断 AFFECTED → 建议 0.30.0

首次规划缺失字段被 Schema 拦截，经 schema_feedback 二次自愈通过；同时保留结构化字段与正文原文定位供核对。

结合历史 vLLM 0.6.5 完整调查（68.7s，Gate PASS / 答案 COMPLETE），端到端验证了从受约束规划到封存复查的全流程。

工程测试与接口契约：阶段记录分别列示

测试范围	记录结果	环境与解释
历史完整后端	1426 passed	Phase 12-D.3；空 PostgreSQL + Mock LLM
上一代后端	1261 passed	Phase 11-D 阶段日志记录
便携 CI	641 passed	Phase 14A；1 项明确排除
来源归组与关联回归	12 项专项 / 88 项关联	两组存在重叠，纠正同源重复确认实例
前端与接口契约	23 项前端 / 42 项契约	前端测试与 TypeScript 契约校验分别记录
C28 组合复验	91 通过 / 8 失败	首错 CreateProcess / WinError5，尚需复验

各套件不能相加，也不能合并为一次当前全量通过；质量指标另见下一页 AegisBench。

团队最新 49 题自测汇总

35 / 49
整题严格匹配

77 / 94
字段匹配

7 / 10
风险等级字段

统计口径

49 道题、94 个字段；风险等级字段单独按 10 项统计。
自动匹配结果需结合原始证据判断。

数据来源

团队提供的 2026-10-19 最新自测汇总；本次材料同步未重新运行评测。

05 创新与比较

三大设计创新总结 · 四条基线方案对比 · 赛题评分指标映射

设计创新	将服务端必需任务不变量、跨源血缘消歧与固定资产分支比对融为一体。
方案差异	相比关键词检索、RAG-only 与固定工作流，补齐核验与门禁验收闭环。
证据与验证	全面覆盖赛题九初赛功能、性能、架构优化与工程质量要求。

核心创新点总结：三大设计创新构建可核验的 AI 安全调查链

把调查过程
变成可检查的交接

01 **受约束的多 Agent 自主调查架构**

服务端 RequiredTask 必需任务不变量 + 三层复验与二次自愈（C09 实证）

02 **Evidence 驱动与跨源血缘核验机制**

字段区分三档状态，origin() 归并同源转载，纠正 22 次重复确认实例

03 **资产上下文与多维护分支判断闭环**

封存调查时刻版本观察，C08 精准锁定 1.x 维护分支并绑定 1.2.5 修复证据

相较检索与单次生成，补齐三个调查环节

任务组织

检索或单次生成提供资料、文本 → **服务端提取必需任务 + 候选计划经三层契约校验后按 DAG 依赖执行**

证据处理

拿到引用后仍需判断能否支持结论 → **按来源血缘归并同源转载，逐声明核验支持与反证，显式保留冲突**

资产判断

漏洞描述还需与登记环境比较 → **封存固定资产版本快照，精准匹配维护分支，经六维 Gate 封存交付**

方案对比：关键词、RAG-only、固定工作流与 AegisAI

机制维度	关键词路径	RAG-only	固定工作流	AegisAI
资料与生成	精确字段读取	检索后生成	按配置获取资料	注册工具与来源记录
任务组织	无独立规划	通常无独立规划	预设任务与依赖	受约束候选计划
证据核验	返回原文片段	不由生成本身保证	可编码核验规则	按血缘归组后逐声明核验
资产适用性	读取资产字段	需额外接入资产判断	可编码版本比较	固定观察与维护分支连接
最终验收	检索列表	生成答案与引用	可配置验收节点	六类 Gate 与结构化答案

差异集中在目标约束、来源血缘核验与资产分支判断；整体优势仍需同口径对比，不由机制表直接推出。

评分要求对应的实现与验证记录

评分要求	作品对应内容	证据与状态
情报监测	多源、增量、RawDocument 与同步记录	接口与采集记录；持续监测时效另测
情报富化	vendor / EPSS / KEV / PoC / Patch / version	六类任务、冲突检测与声明核验
情报问答	规划、调查、核验、风险、AnswerEnvelope	C08 / C09 HTTP 记录与工作台截图
Agent 架构	必需任务约束、多角色产物与工具编排	C09 有限预算内的字段修正案例
自动化与异常处理	依赖调度、领域回滚、幂等与状态留存	成功、失败和部分执行分别追踪
文档与演示	设计图、接口契约、实机与测试材料	原文、产物、轨迹及历史记录可回查

功能完整性、性能与质量分项提供证据；不以测试数量代替准确率、时效或多跳推理达标结论。

适用边界与下一步演进

当前适用边界

授权库存

面向用户登记资产与版本观察，登记值不冒充实际扫描结果。

静态 PoC 关联

候选发现和引用核验不等同于执行利用，不据此宣称漏洞可利用。

显式不确定性

来源冲突、缺失版本和范围不可比较时保留缺口或转人工复核。

演进方向

策略绑定

显式绑定风险政策的身份、版本与验收规则。

范围差异

单独识别公告正文与结构化版本范围差异。

独立评测与时效

按公告簇隔离留出集，补充持续采集延迟及稳定性评测。

授权应用扩展

逐步对接企业 SBOM 与受控补丁验证流程。

AegisAI

感谢审阅

敬请指正

智能体驱动的 AI 安全知识情报系统